

Information Security Policy

Document owner: Engineering • Last updated: 2025-11-30 • Acknowledgement required annually from all staff

Devices

Every company laptop must have full disk encryption enabled and a screen lock triggering after no more than five minutes of inactivity. Personal devices may access email and Slack but never production systems and never customer data. There is no exception process for this rule and none has ever been granted, including for founders. Laptops are enrolled in remote wipe at the point of provisioning by the operations team, which is why hardware is ordered centrally rather than purchased and reimbursed.

Credentials

All accounts require multi-factor authentication. Hardware keys are provided on request and are strongly preferred for anyone holding production access. SMS is not accepted as a second factor for any internal system, and where a vendor supports only SMS that vendor requires a written exception from the CTO before adoption. Credentials are stored in 1Password and nowhere else. A credential posted in a Slack message, a Linear ticket, or a code comment is treated as compromised and must be rotated, and this applies equally where the channel was private, because the retention and export surface of a private channel is identical to that of a public one.

Production access

Access type	Approval	Duration	Additional control
Read, production database	Direct manager	12 hours, time limited	Logged
Write, production database, outside a migration	Direct manager	Session only	Second engineer present on a call; session recorded
Write, via reviewed migration	Code review per NV-ENG-050	Deploy only	Platform team review required
Customer event payload inspection	Direct manager	Single incident	Never copied to a local environment

Table 1. Production access controls.

Production access follows least privilege and is granted per role rather than per person, which means that adding someone to a role grants everything that role holds and there is no partial grant. Customer event payloads are treated as customer data in all circumstances and are never copied into a local environment, never pasted into a ticket, and never included in a screenshot. Where a support investigation requires a payload, it is inspected in place through the internal tooling that logs the access.

Reporting

Any suspected security incident must be reported to the security address within one hour of suspicion, not within one hour of confirmation. The distinction is the entire point of the rule. Reporting something that turns out to be nothing has never once been held against anyone here and will not be. A suspected security incident follows the same severity scale as an operational incident, with one addition: any confirmed unauthorised access to customer data is automatically S1 regardless of scope, volume, or whether the access was internal.

Vendors

New vendors that will store or process customer data require a written review before any contract is signed. The review covers data location, the vendor's own subprocessor list, breach notification terms and timescales, and

deletion on termination. Vendors touching only internal data require manager approval alone. The vendor register is maintained by finance and reviewed twice yearly, and any vendor in the register that has not been used for two consecutive quarters is flagged for cancellation, which is as much a cost control as a security one.

Departures

Laptops are wiped remotely and returned to operations on termination. Access is revoked within one hour of the end of the last working day for voluntary departures, and within 15 minutes for involuntary ones. Revocation is performed by operations against a standing checklist rather than by the departing employee's manager, and the checklist is reviewed after every departure. Shared credentials that the departing employee held are rotated regardless of the circumstances of the departure.